



AUDIT REPORT

September 2026

For



Table of Content

Executive Summary	03
Number of Security Issues per Severity	04
Summary of Issues	05
Verified Mint Configuration	06
■ Low Severity Issues	08
1. Transfer fee rate remains mutable by a live authority	08
2. Accrued withheld fees are sweepable by a single withdraw authority	09
■ Informational Severity Issues	10
1. Off-chain metadata is served through a single centralised gateway URL	10
Closing Summary & Disclaimer	11

Executive Summary

Protocol Name Seasons

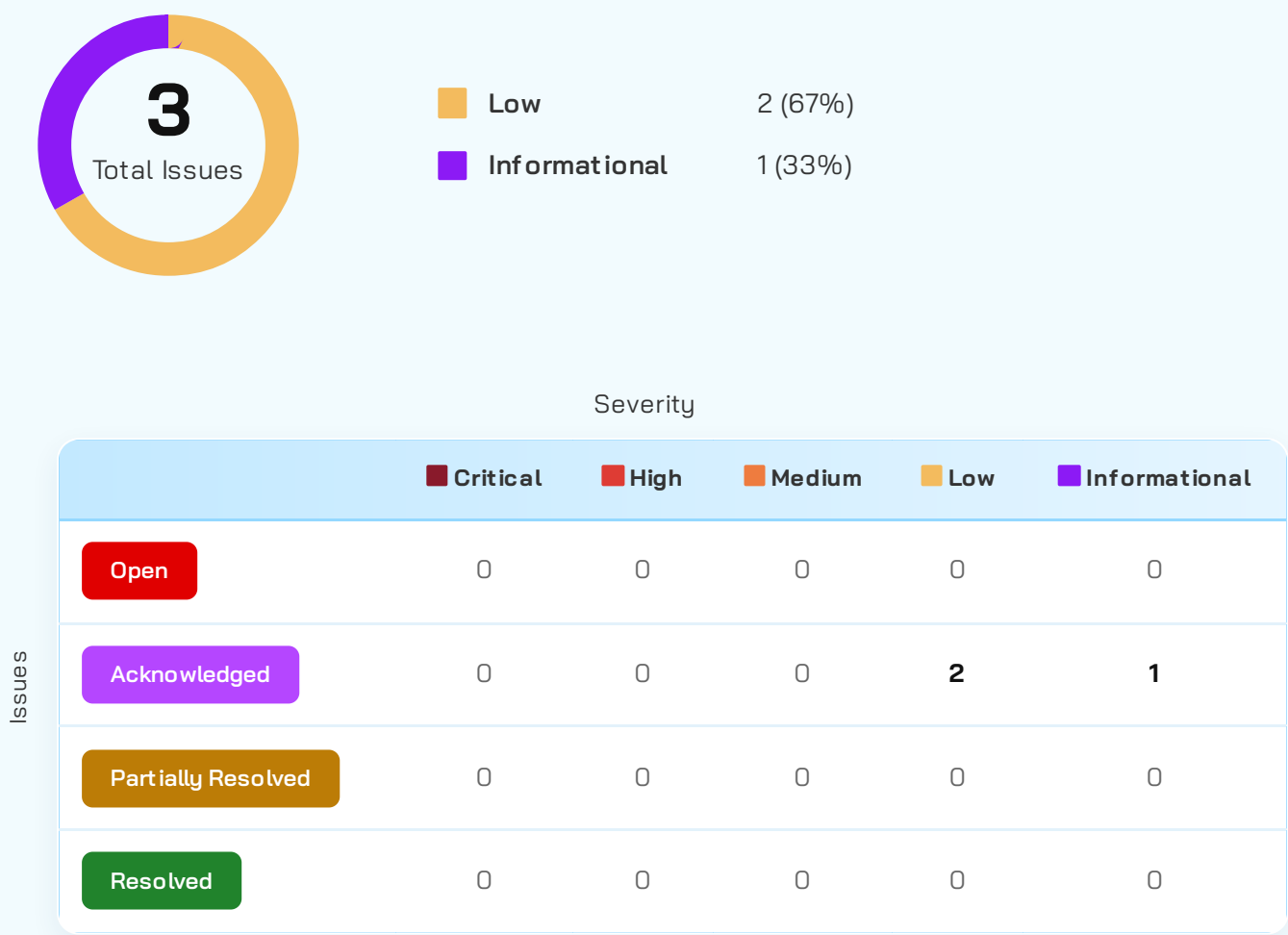
Protocol Overview Seasons is an on-chain liquidity and yield system on Solana. The native SEAS token entitles holders to periodic distributions paid in a basket of alternative assets, and wallets holding a qualifying balance participate as non-custodial nodes in that distribution. The distribution model is funded substantially by transfer fees levied at the token level, which is the reason the mint is deployed under Token-2022 rather than the legacy SPL Token program.

Scope and Limitations This review covers the configuration of the SEAS mint account and the token extensions enabled on it. It is a token-level assessment, not an assessment of the Seasons protocol as a whole.

The following are explicitly outside the scope of this report:

- Any on-chain program implementing yield calculation, node registration or distribution logic. No program source was provided or reviewed.
- Liquidity pool configuration, LP token custody and lock status.
- Off-chain infrastructure, oracles, keepers and treasury operations.
- Economic sustainability of the yield model.

Number of Issues per Severity



Summary of Issues

No issue was identified that allows an external party to take user funds directly. Both Low findings are centralisation findings: privileged keys retained on the mint that, if misused or compromised, would materially harm holders. Neither can be discharged by a code change; both are closed by revoking or decentralising the authority in question.

Issue No.	Issue Title	Severity	Status
1	Transfer fee rate remains mutable by a live authority	Low	Acknowledged
2	Accrued withheld fees are sweepable by a single withdraw authority	Low	Acknowledged
3	Off-chain metadata is served through a single centralised gateway URL	Informational	Acknowledged

Verified Mint Configuration

The following state was read directly from the mint account and forms the evidentiary basis for the findings below.

Token Metadata extension – enabled

Name	Value
Name	Seasons
Symbol	SEAS
Update authority	NULL (revoked)
Metadata URI	https://ipfs.filebase.io/ipfs/QmTqYYsGD24m4rKYw6RZeEuqj4zLH8_R6Yc2yueFAqGPEf
additionalMetadata	Empty array
Metadata account	The mint itself

Metadata Pointer extension – enabled

Name	Value
Metadata address	7GdpaeSzvKx1a78rRkU11KstM1x8naMmMmpWQnQSEAS (self-referential)

Transfer Fee Config extension – enabled

Name	Value
Transfer fee rate	1,000 bps (10%)
Maximum fee ceiling	10,000 bps (100%)
Transfer fee authority	Live account
Withdraw withheld authority	Live account

Low Severity Issues

Transfer fee rate remains mutable by a live authority

Acknowledged

Category

Centralisation / Access Control

Path

SEAS mint account

Description

The TransferFeeConfig extension is enabled and its `transfer_fee_config_authority` is set to a live account rather than `None`. Any holder of that key can submit a `SetTransferFee` instruction and change both the fee rate in basis points and the maximum fee ceiling. The Token-2022 program caps the fee at 10,000 basis points, so the authority is technically able to raise the rate from the current 1,000 bps (10%) to 10,000 bps (100%). At 100% every transfer would deliver nothing to the recipient while the full amount accrues as withheld fees, which is functionally indistinguishable from a honeypot. Mitigating factors Token-2022 does not apply a new fee immediately. `SetTransferFee` writes into `newer_transfer_fee` and schedules it for the current epoch plus two, so an unfavourable change is visible on-chain roughly two to four days before it can take effect, and the older rate continues to apply until then. At the time of review the current and future fee epochs are identical (892) and both rates read 10%, so no fee change is pending.

Recommendation

- Once the fee schedule is considered final, set the transfer fee authority to `None` to make the rate permanently immutable.
- If the rate must stay adjustable, move the authority to a Squads multisig or a timelocked program-derived address rather than a single keypair, and publish the address and its signer set.
- Publish the two-epoch delay and a monitoring endpoint so holders can independently verify that no fee change is queued.

Seasons Team Comment

The Mutable Fee Config is a deliberate feature and key vector of the Yield 3.0 mechanism, which a DAO will eventually govern in the future. It is one of the gauges that must remain configurable for the mechanism to efficiently adapt to operational circumstances. That said, we are open to exploring and implementing an 'Upper Bound' lockout mechanism that will make it impossible to go over 1,000 bps.

Low Severity Issues

Accrued withheld fees are sweepable by a single withdraw authority

Acknowledged

Category

Centralisation / Key Management

Path

SEAS mint account

Description

The `withdraw_withheld_authority` is set to a live account. This authority can call `WithdrawWithheldTokensFromMint` and `WithdrawWithheldTokensFromAccounts` to sweep every unit of fee that the transfer fee extension has withheld across all token accounts.

At the time of review the withheld balance stands at 275,186.47106456 SEAS. Because transfer fees are the input to the protocol yield engine, this key sits directly on the protocol revenue path rather than on a peripheral function, so its compromise would be a loss of protocol funds and not merely an operational inconvenience.

Recommendation

- Hold the withdraw authority in a multisig with a threshold of at least 2-of-3, ideally under Squads.
- Harvest frequently. A short harvest interval bounds the maximum value ever exposed to a single key compromise.
- Disclose the withdraw authority address and the destination treasury in public documentation so that harvests are externally verifiable.

Seasons Team Comment

Yes, we will transition the transfer fee withdraw authority to our multi-sig Squad.

Informational Severity Issues

Off-chain metadata is served through a single centralised gateway URL

Acknowledged

Category

Availability

Path

SEAS mint account

Description

The metadata URI is an HTTPS gateway address on ipfs.filebase.io rather than a protocol-native ipfs:// URI carrying the bare CID. The content itself is content-addressed, so the JSON and image behind the CID cannot be altered without changing the CID, and integrity is therefore preserved.

Availability is not. Resolution depends on that specific gateway remaining online and on the CID remaining pinned. Clients that do not strip the gateway prefix and resolve the CID themselves will show broken metadata if the gateway is unreachable.

Because the update authority is revoked, this URI cannot be corrected later. The dependency is permanent.

Recommendation

- Pin the CID with at least two independent providers and on a self-hosted node, and monitor resolution continuously.
- Ask major wallets and explorers to resolve the CID directly rather than proxying the hardcoded gateway host.
- For any future mint, prefer an ipfs://<CID> URI so that clients choose their own gateway.

Seasons Team Comment

We have to work around this as metadata update rights have been revoked. Since nothing critical is being impacted by this, we will rely on front-ends to host the information moving forward.

Closing Summary

The token is working as intended with the following things:

- ✓ Mint Authority: null
- ✓ Freeze Authority: null
- ✓ Update Authority: null
- ✓ Current Supply: 999,999,999.80449592
- ✓ Decimals: 8

Disclaimer

At QuillAudits, we have spent years helping projects strengthen their smart contract security. However, security is not a one-time event—threats evolve, and so do attack vectors. Our audit provides a security assessment based on the best industry practices at the time of review, identifying known vulnerabilities in the received smart contract source code.

This report does not serve as a security guarantee, investment advice, or an endorsement of any platform. It reflects our findings based on the provided code at the time of analysis and may no longer be relevant after any modifications. The presence of an audit does not imply that the contract is free of vulnerabilities or fully secure.

While we have conducted a thorough review, security is an ongoing process. We strongly recommend multiple independent audits, continuous monitoring, and a public bug bounty program to enhance resilience against emerging threats.

Stay proactive. Stay secure.

About QuillAudits

QuillAudits is a leading name in Web3 security, offering top-notch solutions to safeguard projects across DeFi, GameFi, NFT gaming, and all blockchain layers. With seven years of expertise, we've secured over 1400 projects globally, averting over \$3 billion in losses.

Our specialists rigorously audit smart contracts and ensure DApp safety on major platforms like Ethereum, BSC, Arbitrum, Algorand, Tron, Polygon, Polkadot, Fantom, NEAR, Solana, and others, guaranteeing your project's security with cutting-edge practices.



8+ Years of Expertise	1M+ Lines of Code Audited
50+ Chains Supported	1500+ Projects Secured

Follow Our Journey



AUDIT REPORT

September 2026

For



Canada, India, Singapore, UAE, UK

www.quillaudits.com audits@quillaudits.com